

Risk, Compliance & Controls in Process Design

Embedding internal controls throughout a process ensures objectives are met and compliance is maintained ¹. Controls can be **preventive** (stop errors before they occur) or **detective** (catch issues afterward) ¹ ². Embedding controls means weaving checks into each step (for example, mandatory approvals or system validations) so that policy and regulatory requirements are met as part of normal workflow. For instance, requiring manager approval on large transactions (preventive) and reconciling ledgers monthly (detective) are common methods ¹ ³.

Control Types

- **Preventive Controls** – stop errors or fraud *before* they happen. These include approvals, authorizations, validations, and segregation of duties ². (E.g. requiring manager sign-off for high-value orders ².)
- **Detective Controls** – find and flag errors *after* they occur. Examples are reconciliations, exception reports, audits, and system logs ³. (E.g. monthly bank reconciliations that uncover posting errors ³.)
- **Directive Controls** – formal policies, procedures, and work instructions that guide operations. These ensure risks are addressed by clear guidance (e.g. compliance policies, standard operating procedures) ⁴.
- **Corrective Controls** – actions to correct issues once detected. These include root-cause procedures, training, and process updates to prevent recurrence ⁵.
- **Manual vs Automated Controls** – by implementation: manual controls rely on people (e.g. hand-counting inventory), while automated controls are built into systems (e.g. ERP three-way match) ⁶. Many organizations aim to automate controls where feasible to reduce manual effort ⁶.

Use a mix of these types (preventive, detective, directive, corrective) and methods (manual vs automated) for robust coverage ² ³.

Risk Assessment Basics

Effective process control starts with **risk assessment**. Key steps are:

- **Identify Risks:** List potential failures (fraud, error, compliance breach, etc.). Risks can be strategic, operational, financial, or external ⁷.
- **Analyze Each Risk:** Rate the *likelihood* (probability) and *impact* (severity) of each risk event. Use a simple scale (e.g. Low/Medium/High) or numeric rating ⁸ ⁷.
- **Prioritize via Risk Matrix:** Plot risks on a likelihood-vs-impact matrix ⁸ ⁷ to categorize them (e.g. high-severity/high-likelihood in red, low-low in green). Prioritize controls for the highest-rated cells.
- **Respond & Mitigate:** Determine controls for top risks (e.g. the “high” cells). Design controls that reduce either likelihood or impact.

A typical risk matrix (likelihood vs impact) looks like:

Likelihood ↓ \ Severity →	Low	Medium	High
High	Medium	High	Critical
Medium	Low	Medium	High
Low	Low	Low	Medium

Use this to record scoring. For example, a routine supply delay might be Medium likelihood, Low impact (rated “Low”), whereas catastrophic data loss could be Low likelihood, High impact (also “High” risk). By visualizing risks, teams focus on mitigating the most significant threats ⁸ ⁷.

Segregation of Duties (SoD)

Segregation of duties is a core control to reduce fraud and error ⁹ ¹⁰. **Principle:** No single individual should have end-to-end control of a transaction or asset. Tasks should be split so that at least two people share responsibility. For example, the person who approves an invoice should not also process the payment ¹⁰. Hyperproof notes that SoD breaks tasks into four functions—authorization, custody, recordkeeping, and reconciliation—and no one person should hold multiple roles across these categories ⁹ ¹¹. In practice: - **Example:** In an accounts-payable process, one person can create purchase orders while another issues payments ¹⁰. - **Example:** A developer who writes code should not be the only one who can deploy it to production ⁹.

Implementing SoD creates checks and balances; if one person makes an error or commits fraud, another person’s involvement makes it more likely to be caught ⁹ ¹⁰.

Evidence Capture

Good process design demands an **audit trail** of controls. Every control activity should generate *evidence* (logs, forms, signatures) that can be reviewed. Key practices: - **Document Controls:** Define who does what and where evidence is stored. Attach supporting records (e.g. system logs, signed checklists) to each control step ¹² ¹³. - **Centralize Evidence:** Store logs, reports, and documents in a central repository or system with revision tracking. Ensure each piece is indexed and time-stamped ¹². - **Use Technology:** Automated controls (system checks, digital logs) inherently capture evidence; for manual tasks, require forms or digital entry. For example, link an ERP invoice approval to an audit log that records approver ID and timestamp ¹². - **Maintain Trails:** Retain records (electronic or paper) for the required retention period. A well-structured evidence chain “connects documented controls to their performance metrics,” ensuring verifiable proof of compliance ¹².

Consistent documentation minimizes audit surprises: clearly recording *what, who, when* and *how* for each control makes it easy to verify processes later ¹⁴ ¹³.

Compliance Mapping

Lightweight compliance mapping means linking process steps and controls to applicable laws or standards. To implement: - **Identify Obligations:** List major regulations or requirements relevant to the process (e.g. SOX financial controls, HIPAA for patient data, GDPR for personal data, ISO/IEC standards, industry-specific rules). - **Map to Controls:** For each requirement, note which control or procedure satisfies it. Create a simple matrix (Regulation vs. Process/Control). For example, map “Data protection policy” to specific steps in a customer onboarding process ¹⁵. - **Document Relationships:** Record how each regulation is addressed. For instance, map GDPR articles to data-handling steps and privacy controls. - **Use Updates:** Update this map as laws change. Good mapping lets you see gaps (unaddressed obligations) or redundancies (multiple controls for one requirement).

As one GRC glossary notes, compliance mapping “involves identifying, analyzing, and documenting the relationships between regulatory requirements and an organization’s policies, procedures, and controls” ¹⁵. Even a simple spreadsheet or annotation can highlight needed controls without extensive overhead.

Control Catalog (Starter)

Create a baseline list of standard controls (a “catalog”) to reuse across processes. Example entries:

- **Approvals & Authorizations:** Mandatory manager sign-off on orders/payments above limits (preventive).
- **Segregation of Duties:** Separate roles for critical steps (e.g. one person enters transactions, another reconciles them).
- **Reconciliations:** Periodic matching of related records (bank vs ledger, inventory counts vs system) ³ (detective).
- **Access Controls:** Role-based permissions in IT systems (only authorized users can perform actions).
- **Physical/Asset Controls:** Locks, inventory counts, and physical safeguards on valuable assets.
- **Standard Policies/Procedures:** Documented SOPs and training (directive) to guide consistent execution.
- **Audit Logging:** Enable system logs for key events (user logins, changes to critical data).
- **Exception Reporting:** Automated flags for unusual transactions (e.g. duplicate invoice detection) ³.
- **Periodic Reviews:** Regular internal reviews or audits of the process to catch anomalies.

Each control should include its objective and what risk it addresses. This starter catalog can be expanded per process (for example, adding a **credit check** control for sales processes, or a **background check** control for employee onboarding).

Risk Matrix Template

Use a structured table to score and document risks. For example:

Risk	Likelihood (L/M/H)	Impact (L/M/H)	Risk Level
Fraudulent payment	High	High	Critical
Data entry error	Medium	Medium	Medium
Regulatory compliance miss	Low	High	High

(Key: H=High, M=Medium, L=Low.) Assign risk levels by intersecting likelihood vs impact (as in the earlier matrix). This simple template (which can be done in a spreadsheet) helps track each risk's score and residual status, ensuring managers see the biggest threats.

Example: Order-to-Cash Process (Mini Case)

Consider an **Order-to-Cash** workflow:

- **Order Entry:** Customer places order. *Preventive:* System enforces a credit-check rule; orders above threshold require manager approval. *SoD:* Sales rep entering orders is not the one who approves them.
- **Shipment/Pick-Pack:** Warehouse picks goods. *Control:* Dual custody – the picker confirms items, and a separate packer/inspector verifies quantities. *Evidence:* Checklists and scanned packing slips are attached to the order record.
- **Invoicing:** Once shipped, invoice is generated. *Preventive:* Invoicing system automatically matches shipment to order (three-way match) to avoid billing errors. *Detective:* Accounts receivable reconciles daily sales to recorded invoices.
- **Payment:** Customer pays. *SoD:* One person applies payments; another does bank reconciliation. *Preventive:* Payments over a limit require CFO approval. *Evidence:* Bank statements and payment logs are archived.
- **Outputs/Risks:** Controls address risks like unapproved sales, shipping wrong items, duplicate invoices, or theft of cash. A risk matrix for this process might flag “unauthorized discount” as Medium likelihood/High impact, triggering a preventive control (approval threshold).

Example: Employee Onboarding (Mini Case)

For a **New Hire Onboarding** process:

- **Application Review:** HR screens candidate. *Directive:* HR follows a documented policy (e.g. background check requirements). *SoD:* One recruiter screens candidates; hiring manager approves the final candidate.
- **Account Provisioning:** IT creates user accounts. *SoD:* HR initiates a request; IT security approves access levels. *Evidence:* HR system logs the hire date and required training assignments.
- **Training & Compliance:** New hire completes mandatory training (e.g. safety, security). *Preventive:* System enrollment in courses is triggered automatically by hire. *Detective:* HR audits completion reports to ensure all required modules were done.
- **Policy Acknowledgement:** Employee reads handbooks. *Evidence:* Signed acknowledgments are stored electronically (timestamped). This maps to regulatory training requirements (e.g. data privacy consent).

These examples show controls at each step: approvals, dual review, system checks, and record-keeping, all tailored to typical order-to-cash and HR processes. By designing controls into the flow, the organization reduces risk and builds an auditable trail without disrupting operations.

Key Takeaways: Embed a mix of preventive and detective controls at each process step, separate roles to enforce checks, document evidence of each control, and map processes to key regulations. Use simple tools (checklists, risk matrices) to guide analysis. This disciplined approach makes compliance “lightweight” by building it into routine workflows, rather than treating it as an afterthought ¹ ⁹ .

Sources: Authoritative guides on internal controls and risk management ¹ ² ³ ⁹ ⁸ ⁷ ¹⁶ ¹⁵ . These emphasize prevention vs detection, SoD, risk matrices, evidence trails, and compliance mapping.

¹ Understanding Internal Controls: Essentials and Their Importance

<https://www.investopedia.com/terms/i/internalcontrols.asp>

² ³ ⁴ ⁵ Risk Control Techniques: Preventive, Corrective, Directive, And Detective (PCDD)

<https://financialcrimeacademy.org/risk-control-techniques-pcdd/>

⁶ ¹³ RPA in Finance: Automated Internal Controls Examples

<https://digitalworkforce.com/rpa-news/rpa-in-finance-how-to-automate-90-of-your-companys-internal-controls/>

⁷ Risk Assessment Matrix: Overview and Guide

<https://auditboard.com/blog/what-is-a-risk-assessment-matrix>

⁸ What is a risk assessment matrix? An overview

<https://legal.thomsonreuters.com/blog/what-is-a-risk-assessment-matrix/>

⁹ ¹¹ Segregation of Duties: What it is and Why it's Important - Hyperproof

<https://hyperproof.io/resource/segregation-of-duties/>

¹⁰ What are some common examples of Segregation of Duties

<https://www.safepaas.com/articles/what-are-some-common-examples-of-segregation-of-duties/>

¹² ¹⁴ ¹⁶ Documenting SOC 2: Audit-Ready Evidence | ISMS.online

<https://www.isms.online/soc-2/controls/audit-ready-evidence-how-to-document-and-present-soc-2-controls/>

¹⁵ Uno.ai - Understanding GRC Term: Compliance Mapping

<https://grc-glossary.uno.ai/compliance-mapping/>